

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-27 09:00 WIB

Top 5 Highlights

- Scans for ESAFENET CDG 3 Document Management System Weak Logins, (Sun, Jul 26th)
- GitHub, PyPI add time-based defenses against supply chain attacks
- [+24h Old] Week in review: ServiceNow pre-auth RCE exploited in the wild, Hugging Face breached
- [+24h Old] Malvertising Sends Malware in Pieces, Then Makes the Browser Build the Executable
- [+24h Old] Malicious sites use JavaScript to build malware in browser memory

Threat Intelligence (10)

01. GitHub, PyPI add time-based defenses against supply chain attacks

GitHub and PyPI (Python Package Index) have introduced a time-based mechanism in the Dependabot dependency management tool to protect against supply-chain attacks and to limit their impact. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.bleepingcomputer.com/news/security/github-pypi-add-time-based-defenses-against-supply-chain-attacks/>

02. [+24h Old] Malvertising Sends Malware in Pieces, Then Makes the Browser Build the Executable

A malvertising operation dubbed SourTrade is making victims' browsers build the final Windows executable themselves, using a legitimate Bun runtime as its base instead of serving one complete malicious file from a fixed URL. Confiant, which detailed the campaign on July 23, 2026, said it has operated since late 2024 and impersonated TradingView, Solana, and...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/malvertising-sends-malware-in-pieces.html>

03. [+24h Old] Malicious sites use JavaScript to build malware in browser memory

A massive malvertising campaign is using fake Solana, Luno, and TradingView webpages with malicious JavaScript that instructs browsers to assemble malware directly in memory. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/malicious-sites-use-javascript-to-build-malware-in-browser-memory/>

04. [+24h Old] CTM360 Research Reveals How Insurance Phishing Has Evolved Into Real-Time Account Hijacking

For years, phishing campaigns targeting financial institutions followed the same playbook. Victims were tricked into entering usernames and passwords, attackers collected the credentials, and accounts were compromised later when an opportunity arose. That model is changing. Recent investigations into insurance-focused phishing operations

reveal a more immed...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/07/ctm360-research-reveals-how-insurance.html>

05. [+48h Old] Golden Chickens malware-as-a-service resurfaces with four new families

The Hacker News disclosed that the threat actors behind the Golden Chickens malware-as-a-service (MaaS) ecosystem have resurfaced with four new malware families, indicating that the operators are showing no signs of stopping despite extensive public disclosures into their inner workings.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/golden-chickens-malware-as-a-service-resurfaces-with-four-new-families>

06. [+48h Old] UK issues alert over Russian zero-click email attacks

The UK's National Cyber Security Centre (NCSC) issued an alert regarding a new 'zero-click' threat campaign orchestrated by Russian state-backed hackers targeting organizations across critical sectors, according to a recent report by IT Pro.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/uk-issues-alert-over-russian-zero-click-email-attacks>

07. [+48h Old] BlueNoroff Zoom Phishing Kit Profiles Crypto Wallets Before Malware Delivery

The North Korean threat actors behind the ClickFix-style campaigns that employ typosquatted Zoom and Microsoft Teams domains have been found to operate an active phishing kit to impersonate the videoconferencing platforms in social engineering campaigns designed to deliver malware. "BlueNoroff has operationalised trust abuse by combining compromised industr...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/07/bluenoroff-zoom-phishing-kit-profiles.html>

08. [+48h Old] Hotel Wi-Fi Routers Compromised to Steal Corporate Login Credentials From Visitors

Researchers at ReliaQuest warned of widespread DNS poisoning attacks targeting the hospitality sector as part of a cyber espionage campaign

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/hotel-wifi-dns-poisoning/>

09. [+48h Old] Beyond the Play Store: How Android threats really spread

Some threats never pass through the Play Store. Others arrive later in seemingly legitimate updates. Here's how Malwarebytes detects both.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/inside-malwarebytes/2026/07/beyond-the-play-store-how-android-threats-really-spread>

10. [+48h Old] ChatGPT Among Top 10 Most Impersonated Brands in Phishing Attacks, Says Check Point

OpenAI's chatbot tool ChatGPT ranked among the top 10 most impersonated brands in phishing attacks for the first time

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/chatgpt-most-impersonated-brands/>

Latest Vulnerabilities (10)

01. Scans for ESAFENET CDG 3 Document Management System Weak Logins, (Sun, Jul 26th)

ESAFENET's CDG showed up in our data before. The company focused on secure document management and data leakage prevention solutions. The "CDG" stands for "Content Data Guard", and the product appears to be mostly targeting the Chinese market [1]. Sadly, like so many security products, it suffers from basic security vulnerabilities like SQL Injec...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://isc.sans.edu/diary/rss/33184>

02. [+24h Old] Week in review: ServiceNow pre-auth RCE exploited in the wild, Hugging Face breached

Here's an overview of some of last week's most interesting news, articles, interviews and videos: AI agents are still logging in as humans Most large companies run more than one AI platform at the same time. Developers pull up coding assistants, marketing teams lean on writing tools, and analysts query enterprise search across separate vendors. Single-provi...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/07/26/week-in-review-servicenow-pre-auth-rce-exploited-in-the-wild-hugging-face-breached/>

03. [+24h Old] Fastjson 1.x RCE Vulnerability Targeted in Attacks With No Patched Available

Security firms ThreatBook and Imperva say attackers are targeting a critical flaw in Fastjson, Alibaba's JSON library for Java. In affected Spring Boot applications, a malicious JSON request can execute code without authentication, with the privileges of the Java process. Tracked as CVE-2026-16723, the vulnerability carries an Alibaba-assigned CVSS score of...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/fastjson-1x-rce-vulnerability-targeted.html>

04. [+24h Old] Researcher Publishes GitLab RCE PoC Letting Authenticated Users Run Commands as Git

Security researchers at depthfirst published working exploit code on July 24 for a GitLab flaw that GitLab patched six weeks earlier, on June 10. It runs commands as git on any self-managed 18.11.3 server that has not taken the update. Any authenticated user who can push to a project can run it. The attacker commits a crafted Jupyter notebook and opens its...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/researcher-publishes-gitlab-rce-poc.html>

05. [+24h Old] CI0p Affiliates Target Internet-Exposed PTC Windchill and FlexPLM with Unauthenticated RCE

Threat actors linked to the Cl0p (aka Chubby Scorpion, FIN11, Graceful Spider, and Lace Tempest) ransomware campaign are exploiting flaws in internet-exposed PTC Windmill and FlexPLM deployments as part of a new data extortion campaign. "Attackers chain a pre-authentication information disclosure in the FlexPLM WSDL endpoint with a server-side flaw in the W...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/cl0p-affiliates-target-internet-exposed.html>

06. [+48h Old] Rockwell Patches Code Execution Flaws in Arena Simulation Software

A researcher has explained how an attacker could exploit these vulnerabilities to target industrial organizations. The post Rockwell Patches Code Execution Flaws in Arena Simulation Software appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.securityweek.com/rockwell-patches-code-execution-flaws-in-arena-simulation-software/>

07. [+48h Old] GitHub to implement two-tier bug bounty program amid AI-generated report surge

GitHub is launching a two-tier bug bounty program starting July 27, 2026, in response to an increase in low-quality, AI-generated vulnerability reports.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/github-to-implement-two-tier-bug-bounty-program-amid-ai-generated-report-surge>

08. [+48h Old] AI assistant used in cyberattack on Thailand's Ministry of Finance

An open-source AI assistant named Hermes was used in a cyberattack targeting Thailand's Ministry of Finance, compromising sensitive personnel data and internal systems.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/ai-assistant-used-in-cyberattack-on-thailands-ministry-of-finance>

09. [+48h Old] OnTrac notifies customers of data breach after network hack

OnTrac parcel delivery company is informing that hackers breached its corporate network and may have accessed personal details belonging to its customers. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/ontrac-notifies-customers-of-data-breach-after-network-hack/>

10. [+48h Old] Hermes AI agent used to automate attack on Thai Finance Ministry

A threat actor used the open-source Hermes AI agent in unattended "YOLO" mode to automate post-exploitation activity during an alleged breach of Thailand's Ministry of Finance. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/hermes-ai-agent-used-to-automate-attack-on-thai-finance-ministry/>

Data Breach & Cybercrime (10)

01. [+24h Old] ShinyHunters data leaks fuel \$2,000 sextortion email scam

Threat actors are using email addresses exposed in data breaches leaked by the ShinyHunters extortion group to send sextortion emails demanding \$2,000 in Bitcoin. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/shinyhunters-data-leaks-fuel-2-000-sextortion-email-scam/>

02. [+48h Old] DevMan RaaS Portal Centralizes Payload Builds, Victim Management, and Affiliate Payouts

The operators of the DevMan ransomware-as-a-service (RaaS) scheme are maintaining a dedicated web platform that offers affiliates the ability to build payloads, oversee earnings, and manage various aspects related to victims. Swiss cybersecurity company PRODAFT is tracking the centrally administered RaaS operation under the name Funky Mantis. "The portal co...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://thehackernews.com/2026/07/devman-raas-portal-centralizes-payload.html>

03. [+48h Old] Vatican's 'Click to Pray' app leaks personal data of hundreds of thousands

A popular Vatican website and mobile app, 'Click to Pray,' was found to be leaking the names and email addresses of hundreds of thousands of its users.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/brief/vaticans-click-to-pray-app-leaks-personal-data-of-hundreds-of-thousands>

04. [+48h Old] Cybersecurity threats escalate with ransomware, data breaches and online fraud

The cybersecurity landscape continues to expand with increasing risks for governments, businesses and consumers.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/cybersecurity-threats-escalate-with-ransomware-data-breaches-and-online-fraud>

05. [+48h Old] US to deny visas to foreign nationals involved in cybercrime

The United States will deny visas to foreign nationals involved in cybercrime, with potential extensions to their immediate families, according to a recent report by The Register.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/us-to-deny-visas-to-foreign-nationals-involved-in-cybercrime>

06. [+48h Old] Don't get fooled by TikTok resin art scams

Scammers are using stolen videos and fake artist profiles to trick people into buying resin art that never arrives. Here's how to spot the warning signs.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/scams/2026/07/dont-get-fooled-by-tiktok-resin-art-scams>

07. [+48h Old] Call of Duty Mobile scam uses fake free points to steal player accounts

A phishing site posing as a free Call of Duty Points giveaway is stealing Activision logins and two-factor authentication codes.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/07/call-of-duty-mobile-scam-uses-fake-free-points-to-steal-player-accounts>

08. [+48h Old] In Other News: Dolphin X AI-Powered Malware, Car Anti-Theft Device Hack, 400 Linux Kernel Flaws

Noteworthy stories that might have slipped under the radar: Siemens ROX II industrial switch vulnerabilities, Russian Zimbra webmail espionage campaign, Stadler Rail ransomware extortion attempt. The post In Other News: Dolphin X AI-Powered Malware, Car Anti-Theft Device Hack, 400 Linux Kernel Flaws appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.securityweek.com/in-other-news-dolphin-x-ai-powered-malware-car-anti-theft-device-hack-400-linux-kernel-flaws/>

09. [+48h Old] Chick-fil-A data breach affects more than 13,000 customers

Chick-fil-A has confirmed that over 13,000 customers had their accounts breached in a wave of credential stuffing attacks targeting its website and mobile app between June 17 and June 19. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/chick-fil-a-data-breach-affects-more-than-13-000-customers/>

10. [+48h Old] The Good, the Bad and the Ugly in Cybersecurity - Week 30

Authorities arrest Kratos's developer, HollowGraph hides C2 in 2050 calendar events, and OpenAI's models breach Hugging Face to steal benchmark answers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-30-8/>